

GMX · SECURITY REVIEW

GMX

Updates 9 30 24.

A security review of Updates 9 30 24.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
GMX	Updates 9 30 24	Guardian	October 2 – October 9, 2024	October 16, 2024

§ 00

Contents.

26 pages — overview, confidence ranking, scope, 16 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 14 findings	P. 09
	Remediation Review · 2 findings	P. 23
§ 05	Disclaimer	P. 25
§ 06	About Guardian	P. 26

§ 01

Overview.

Guardian reviewed Updates 9 30 24 across 2 review rounds. The final report includes 1 High, 2 Medium, 13 Low findings.

AUDIT FIRM	REPOSITORY
Guardian	gmx-io/gmx-synthetics
CLIENT	METHODOLOGY
GMX	Smart contract · Manual · Main Review · Remediation Review
PROJECT	MAIN REVIEW COMMIT
Updates 9 30 24	887b2b55e2fb
PREPARED BY	REMEDATION REVIEW COMMIT
Guardian	a3950ca6c54c
AUDIT WINDOW	
October 2 – October 9, 2024	
FINAL REPORT	
October 16, 2024	

1.1 Confidence Ranking

4 / 5

High Confidence

Guardian assigns a Confidence Ranking of 4 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	1	0	0	0	1
Medium	2	0	0	0	2
Low	13	0	9	0	4
Informational	0	0	0	0	0
All severities	16	0	9	0	7

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence ASSIGNED	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Updates 9 30 24 in `gmx-io/gmx-synthetics`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
H-01	validFromTime Risk Free Trades	Gaming	HIGH	RESOLVED	p. 9
M-01	Gas Multiplier Fee Key Errantly Removed	Validation	MEDIUM	RESOLVED	p. 10
M-02	Order Funds May Be Lost Upon Cancellation	Unexpected Behavior	MEDIUM	RESOLVED	p. 11
L-01	Integrations Broken By Deposit Gas Update	Warning	LOW	ACKNOWLEDGED	p. 12
L-02	Nonzero validFrom Allowed For Market Orders	Validation	LOW	RESOLVED	p. 13
L-03	Dangerous maxFundingFactorPerSecond Configuration	Validation	LOW	RESOLVED	p. 14
L-04	validFromTime Orders Executed Before Their Date	Warning	LOW	ACKNOWLEDGED	p. 15
L-05	Liquidation Fee Uses Round Down Division	Rounding	LOW	RESOLVED	p. 16
L-06	Liquidation Fee Avoided	Gaming	LOW	ACKNOWLEDGED	p. 17
L-07	New Deposit Gas Key Configuration	Warning	LOW	ACKNOWLEDGED	p. 18
L-08	Users Required To Send Extraneous Gas	Logical Error	LOW	ACKNOWLEDGED	p. 19
L-09	Inaccurate Comment	Documentation	LOW	RESOLVED	p. 20
L-10	Users May Provide Less Gas Than Necessary	Configuration	LOW	ACKNOWLEDGED	p. 21

Findings continued.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
L-11	Funding Configuration Invalidates Pending Funding	Unexpected Behavior	LOW	ACKNOWLEDGED	p. 22

REMEDIATION REVIEW

L-01	Invalid Funding Increase With Zero Diff	Logical Error	LOW	ACKNOWLEDGED	p. 23
L-02	diffUsdAfterExponent Precision Loss	Rounding	LOW	ACKNOWLEDGED	p. 24

HIGH **H-01**

RESOLVED

validFromTime Risk Free Trades

CATEGORY Gaming
LOCATION Global
REVIEW Main Review

— DESCRIPTION

The `validFromTime` attribute does not allow non-market orders to be executed until their `validFromTime`. This allows for the gaming of limit orders resulting in risk free trades over short time periods.

Consider the following scenario for a `LimitIncrease` order:

```
orderCreation price goes below trigger validFromTime
-----|-----|-----|-----|-----|----->
price goes above trigger 5 minutes after price goes above trigger
```

In this scenario the `LimitIncrease` order can be executed at the `validFromTime` with the price from when the trigger was satisfied, even though the current market price at the `validFromTime` can be noticeably above the trigger price. This can all happen within a 5 minute timeframe, staying within the `maxPriceAge`. After the `LimitIncrease` order is executed with a stale price, the user can immediately create a `MarketDecrease` order to lock in their risk free profit.

If the price does not move in the way the user would like to achieve this risk free trade, they can simply cancel their limit order or update their `validFromTime` to try again during the next period.

— RECOMMENDATION

Require that non-market orders be executed with prices only after the `validFromTime`.

— RESOLUTION

Status: Resolved.

MEDIUM **M-01**

RESOLVED

Gas Multiplier Fee Key Errantly Removed

CATEGORY Validation
LOCATION Config.sol: 542
REVIEW Main Review

DESCRIPTION

The `EXECUTION_GAS_FEE_MULTIPLIER_FACTOR` key was errantly removed from the `allowedLimitedBaseKeys`, preventing the limited config keeper from being able to configure this value. The value can still be configured by the normal config keeper however.

RECOMMENDATION

Add the `allowedLimitedBaseKeys[Keys.EXECUTION_GAS_FEE_MULTIPLIER_FACTOR] = true;` line back to the `_initAllowedLimitedBaseKeys` function and remove the duplicated `allowedLimitedBaseKeys[Keys.EXECUTION_GAS_FEE_PER_ORACLE_PRICE] = true;` line.

RESOLUTION

Status: Resolved.

MEDIUM **M-02**

RESOLVED

Order Funds May Be Lost Upon Cancellation

CATEGORY Unexpected Behavior
LOCATION Global
REVIEW Main Review

DESCRIPTION

In the deployment plan for the new contract updates the old version of the GMX contracts will be live at the same time as the new version.

The keepers will be configured to execute using the new version of the contracts, however StopIncrease orders which are manually cancelled by users and integrations through the old version of the contracts will experience complete loss of funds. This occurs because the new StopIncrease order type will not register as an increase order in the old version of the contracts.

RECOMMENDATION

Be aware of this risk and warn users and integrations of this potential loss.

RESOLUTION

Status: Resolved.

LOW **L-01**

ACKNOWLEDGED

Integrations Broken By Deposit Gas Update

CATEGORY Warning
LOCATION GasUtils.sol
REVIEW Main Review

DESCRIPTION

The `estimateExecuteDepositGasLimit` function has been updated so that single sided deposits use the same gas expenditure as double sided gas deposits. Additionally the `depositGasLimitKey` has been changed to no longer accept a boolean indicating whether it is a single sided deposit.

These changes will likely cause issues with integrators if they are not informed of the updates.

RECOMMENDATION

Consider informing integrators of these changes.

RESOLUTION

Status: Acknowledged.

LOW **L-02**

RESOLVED

Nonzero validFrom Allowed For Market Orders

CATEGORY Validation
LOCATION OrderUtils.sol: 135
REVIEW Main Review

DESCRIPTION

During order creation in the `OrderUtils.createOrder` function there is no validation preventing users from assigning a nonzero `validFrom` value for market orders.

However the `validFrom` field will have no effect on Market orders. This may result in user's assigning a `validFrom` field for a market order which will then not apply upon order execution.

RECOMMENDATION

Consider whether the `validFrom` field should be validated to be exactly zero when a market order is created to avoid any unexpected behavior.

RESOLUTION

Status: Resolved.

LOW **L-03**

RESOLVED

Dangerous maxFundingFactorPerSecond Configuration

CATEGORY Validation
LOCATION Config.sol
REVIEW Main Review

DESCRIPTION

The limited config keeper is now allowed to configure the `MAX_FUNDING_FACTOR_PER_SECOND` key as it is assigned to `true` in the `allowedLimitedBaseKeys` mapping.

This can be dangerous if the limited config keeper assigns the max funding fee to less than the minimum funding fee which will lead to unexpected results for the funding calculations of a market.

RECOMMENDATION

Consider adding validation to the `_validateRange` function that validates that the max funding factor per second for a market is above the min funding factor per second whenever either the min or max funding factor per seconds are updated.

RESOLUTION

Status: Resolved.

LOW **L-04**

ACKNOWLEDGED

validFromTime Orders Executed Before Their Date

CATEGORY Warning
LOCATION Global
REVIEW Main Review

— DESCRIPTION

In the deployment plan for the new contract updates the old version of the GMX contracts will be live at the same time as the new version. There is a risk that any orders executed through the old contracts would ignore the new validFromTime attribute and execute orders before that specified time.

However the keepers will be configured to execute using the new contracts. This finding simply serves as a warning to document this risk.

— RECOMMENDATION

Be aware of this risk and ensure that all order executions occur through the new contracts.

— RESOLUTION

Status: Acknowledged.

LOW **L-05**

RESOLVED

Liquidation Fee Uses Round Down Division

CATEGORY Rounding
LOCATION PositionPricingUtils.sol: 575
REVIEW Main Review

DESCRIPTION

Throughout the GMX V2 codebase roundup division is used where it is in the protocol's favor and against the favor of the user. However when computing the liquidation fee to charge the amount is computed using round down division.

RECOMMENDATION

Use round up division to compute the `liquidationFees.liquidationFeeAmount`.

RESOLUTION

Status: Resolved.

LOW **L-06**

ACKNOWLEDGED

Liquidation Fee Avoided

CATEGORY Gaming
LOCATION Global
REVIEW Main Review

— DESCRIPTION

A liquidation fee is now charged by the protocol to monetize liquidations, however this fee can be avoided by setting a stop loss order above the liquidation price to close a position right before the liquidation point is reached.

— RECOMMENDATION

Be aware of this gaming and consider if any actions should be done to penalize users who utilize this strategy.

— RESOLUTION

Status: Acknowledged.

LOW **L-07**

ACKNOWLEDGED

New Deposit Gas Key Configuration

CATEGORY Warning
LOCATION —
REVIEW Main Review

DESCRIPTION

The deposit gas key has been changed and must be configured again through the config contract.

RECOMMENDATION

This finding merely serves as a reminder for this. Be sure to populate the new deposit key value in the `dataStore` through the config contract upon deployment.

RESOLUTION

Status: Acknowledged.

LOW **L-08**

ACKNOWLEDGED

Users Required To Send Extraneous Gas

CATEGORY Logical Error
LOCATION OrderUtils.sol: 176
REVIEW Main Review

— DESCRIPTION

In the manual user initiated order cancellation flow the `minHandleExecutionErrorGas` is validated in the `cancelOrder` function. Thus users are required to provide this gas amount even though they are not handling an execution error.

This may cause unintended gas estimation problems and reverts.

— RECOMMENDATION

Consider only requiring that this minimum execution gas is provided while executing an order/autocancelling and not while a user is manually cancelling their order. The user still will not be able to provide less than the required callback gas as the `afterOrderCancellation` function will validate the remaining gas for the callback.

— RESOLUTION

Status: Acknowledged.

LOW **L-09**

RESOLVED

Inaccurate Comment

CATEGORY Documentation
LOCATION Order.sol: 24
REVIEW Main Review

DESCRIPTION

In the comment for the `MarketDecrease` order type it is now mentioned that the order will be frozen if the acceptable price is not reached. However market orders cannot be frozen, instead they will be cancelled.

RECOMMENDATION

Revert the comment to say that the order will be cancelled.

RESOLUTION

Status: Resolved.

LOW **L-10**

ACKNOWLEDGED

Users May Provide Less Gas Than Necessary

CATEGORY	Configuration
LOCATION	Global
REVIEW	Main Review

— DESCRIPTION

The deposit gas limit key is no longer dependent on the amount of distinct tokens being deposited, therefore users and integrations creating deposits through the old contracts will have a different deposit gas execution fee to pay than what is expected by the keepers.

For instance, the new deposit gas requirement is likely to be higher than the single token deposit configuration. In this case users and integrations submitting orders through the old contracts will be required to send less gas than the new contracts would require.

This may be unexpected for keepers and cause them to run a lower margin or even a deficit on some of these orders.

— RECOMMENDATION

Be aware of this potentially unexpected behavior. If necessary, configure the old single token and double token gas key values to be the same as the new single gas key value to match the gas requirements across both versions.

— RESOLUTION

Status: Acknowledged.

LOW **L-11**

ACKNOWLEDGED

Funding Configuration Invalidates Pending Funding

CATEGORY Unexpected Behavior
LOCATION Config.sol
REVIEW Main Review

— DESCRIPTION

The limited config keeper is now allowed to configure the `MAX_FUNDING_FACTOR_PER_SECOND` key as it is assigned to `true` in the `allowedLimitedBaseKeys` mapping.

However the adjustment of the max funding factor per second will in many cases change the funding amount which was pending for the market. This is because capping the maximum to a higher or lower value will change the resulting `fundingFactorPerSecond` which will apply over the past `[lastMarketUpdate, block.timestamp]` period.

Integrations with GMX V2 often rely on the current funding values to measure the value of open positions on GMX. Thus this measurement may become retroactively invalidated once the max funding factor per second is assigned to a different value.

This can happen if the limited config keeper is performing maliciously but also if they are performing honest updates to the max funding factor per second assignment for a market. Additionally this applies to the maximum and minimum funding factor per second configurations which can be made by the normal config keeper.

— RECOMMENDATION

Consider updating the funding in a market before changing the maximum or minimum thresholds for the funding factor per second.

— RESOLUTION

Status: Acknowledged.

LOW **L-01**

ACKNOWLEDGED

Invalid Funding Increase With Zero Diff

CATEGORY Logical Error
LOCATION MarketUtils.sol: 1319
REVIEW Remediation Review

DESCRIPTION

When computing the adaptive funding increase the `isSkewTheSameDirectionAsFunding` variable cannot be true when the `diffUsd` is 0.

```
bool isSkewTheSameDirectionAsFunding = (cache.savedFundingFactorPerSecond > 0 &&  
longOpenInterest > shortOpenInterest) || (cache.savedFundingFactorPerSecond < 0 &&  
shortOpenInterest > longOpenInterest);
```

Therefore the `fundingRateChangeType` will always be an `INCREASE` type in this scenario and as a result funding will increase when it should remain the same.

RECOMMENDATION

Assign `isSkewTheSameDirectionAsFunding` to true in the case where the `diffUsd` is 0.

RESOLUTION

Status: Acknowledged.

LOW **L-02**

ACKNOWLEDGED

diffUsdAfterExponent Precision Loss

CATEGORY Rounding
LOCATION MarketUtils.sol: 1288
REVIEW Remediation Review

— DESCRIPTION

The `Precision.applyExponentFactor` function returns zero if the `floatValue` is less than `1e30`, thus if the `diffUsd` in the `getNextFundingFactorPerSecond` function is less than \$1 it will be rounded to zero for the `diffUsdAfterExponent` result.

— RECOMMENDATION

This only serves to document this behavior, it can be safely ignored and the finding has been marked as acknowledged.

— RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.